

COMPICK

회원 서비스 코드 리뷰

현재까지 구현된 회원가입·로그인·구글 OAuth·계정 복구·마이페이지·배송지 관리 범위

검토 기준	Spring Boot 3.5.16 / Java 21 / Oracle / Thymeleaf / Spring Security
검토 일자	2026년 7월 29일
검토 범위	src/main 및 회원 서비스 통합 테스트
테스트 상태	9개 통과 (실패 0, 오류 0)
문서 목적	현재 품질 진단, 위험 식별, 다음 구현 단계의 기준선 제공

종합 평가

학습·프로토타입 단계의 회원 기능은 완성도가 높다. 계층 분리, 비밀번호 해시, CSRF 기본 보호, 소유권 확인이 적용되어 있다. 운영 전에는 DB 초기화 설정과 계정 상태 판정 방식, 이메일 정규화를 우선 보완해야 한다.

작성 폰트: 한돌움 / 한돌움 Bold

01 요약

결론부터 보는 현재 상태와 우선 조치

현재 구현은 회원 도메인의 주요 사용자 여정을 한 프로젝트 안에서 일관되게 연결했다. 로컬 회원가입 직후 로그인, 일반 로그인, Google OIDC, 아이디 찾기, 비밀번호 재설정, 회원정보 수정, 탈퇴, 배송지 관리가 동작하며 통합 테스트가 핵심 규칙을 확인한다.

영역	평가	요약
기능 완성도	양호	회원 핵심 흐름과 화면이 연결됨
보안 기본기	양호	BCrypt, Spring Security, CSRF 기본값, OIDC 이메일 검증
데이터 안전성	주의	create-drop이므로 앱 종료·재시작 시 데이터가 사라짐
유지보수성	보통 이상	계층은 명확하나 일부 상태 판정과 검증이 문자열 규칙에 의존
테스트	보통	서비스 통합 테스트는 있으나 OAuth 성공 핸들러와 실패 경계 테스트 부족

즉시 권장

- 운영 또는 팀 공용 DB에서는 `spring.jpa.hibernate.ddl-auto=create-drop`을 사용하지 않는다.
- 회원가입 시 이메일을 `trim + lowercase`로 정규화한 뒤 중복 검사와 저장을 수행한다.
- 구글 계정의 '아이디 설정 완료' 상태를 `loginId` 접두어가 아닌 명시적 컬럼으로 관리한다.

판정

현재 상태로 시연과 기능 통합은 가능하다. 실제 데이터 보존이 필요한 환경에 배포하기 전에는 P0 항목을 반드시 처리해야 한다.

02 구조와 책임

현재 패키지 구성과 요청 처리 흐름

계층	주요 구성	책임
Controller	Member, Recovery, Address	요청 검증, 화면 선택, 인증 세션 연결
Service	Member, SocialAccount, EmailVerification, Address	회원 규칙, 트랜잭션, 외부 메일 연동
Repository	Member, SocialAccount, Address, EmailVerification	JPA 기반 영속성 접근
Entity	Member, SocialAccount, Address, EmailVerification	상태와 도메인 변경 메서드 보유
Security	SecurityConfig, OIDC User Service	인가, 폼 로그인, Google OIDC 성공 흐름
View	Thymeleaf templates + CSS	회원 화면, 개인정보 처리방침, 팝업

대표 요청 흐름

브라우저 → Controller → Service → Repository → Oracle 순서로 책임이 분리되어 있다. 인증 성공 후에는 Spring Security Context가 세션에 저장되며, Google 최초 가입은 별도의 아이디·비밀번호 설정 화면으로 분기된다.

일반 회원가입

POST /member/join → JoinForm 검증 → MemberService.join → BCrypt 저장 → AuthenticationManager 인증 → 메인/회원 화면 이동

Google 최초 가입

Google OIDC → CompickOidcUserService → SocialAccountService → 임시 Member 생성 → /member/social-credentials → 최종 로그인 정보 저장

설계상 좋은 점

- 컨트롤러가 직접 Repository를 호출하지 않아 규칙의 위치가 비교적 명확하다.
- 엔티티에 updateProfile, changePassword, withdraw, makeDefault 같은 의도 중심 메서드가 있다.
- 읽기 전용 트랜잭션을 서비스 기본값으로 두고 변경 메서드에만 쓰기 트랜잭션을 적용했다.

03 구현 완료 범위

사용자 관점에서 확인한 기능 목록

기능	상태	구현 메모
로컬 회원가입	완료	아이디 중복, 비밀번호 형식, 이메일, 이름, 전화번호, 약관 검증
가입 직후 로그인	완료	AuthenticationManager로 즉시 인증 세션 생성
일반 로그인	완료	아이디·비밀번호, 로그인 유지, 실패/로그아웃 안내
Google 로그인	완료	OIDC 이메일 검증 및 SOCIAL_ACCOUNT 연결
Google 최초 정보 설정	완료	아이디 중복 확인과 비밀번호 설정 후 로컬 로그인도 가능
아이디 찾기	완료	이름·이메일 확인, 메일 코드 인증, 마스킹 아이디 표시
비밀번호 재설정	완료	아이디·이메일 확인, 인증 코드 1회 사용, BCrypt 재저장
마이페이지	완료	회원 요약, 이름·전화번호 수정, 비밀번호 변경, 탈퇴
배송지	완료	목록·등록·수정·삭제, 회원 소유권 확인, 기본 배송지 1개 유지
개인정보 처리방침	완료	회원가입 화면의 팝업 링크와 별도 공개 경로

범위 밖

상품, 장바구니, 주문 내역, 결제, 관리자 기능은 현재 회원 서비스 리뷰 범위에서 실제 구현 완료 여부를 확인하지 않았다.

04 주요 발견 사항

운영 전 수정이 필요한 항목 - 중요도 순

우선	발견	영향 / 권장 조치
P0	운영 설정에 create-drop	앱 시작 시 스키마 재생성, 종료 시 삭제되어 회원·배송지 데이터가 유실된다. dev/test/prod 프로필을 나누고 운영은 validate 또는 마이그레이션 도구를 사용한다.
P1	로컬 가입 이메일 미정규화	Google·복구 흐름은 소문자화하지만 로컬 가입은 입력값 그대로 검사·저장한다. 대소문자 변형 중복 또는 복구 실패가 가능하다. 저장 전에 trim/lowercase를 공통 적용한다.
P1	Google 설정 상태를 loginId 접두어로 판정	loginId가 google_로 시작하는지 여부가 가입 완료 상태가 된다. 표현 규칙과 업무 상태가 결합된다. credential_setup_completed 같은 명시적 상태를 둔다.
P1	DB 접속정보 기본값이 소스에 존재	MULTI/MULTI가 개발용이어도 저장소 공유 시 노출 범위가 커진다. URL·계정·비밀번호를 환경변수 또는 비밀 저장소로 분리한다.
P2	인증 코드가 log 모드에서 평문 기록	개발 편의 기능이 운영에서 켜지면 계정 복구 코드가 로그에 남는다. 운영 프로필에서 smtp 강제 및 코드 마스킹을 적용한다.
P2	복구 처리의 원자성 경계	인증 코드 소비와 비밀번호 변경이 서로 다른 서비스 트랜잭션이다. 후속 저장 실패 시 코드는 사용 처리될 수 있다. 하나의 유스케이스 트랜잭션으로 묶는다.
P2	OAuth 웹 흐름 테스트 부족	서비스 연결 테스트는 있지만 최초 설정 리다이렉트, 재로그인, 중복 아이디 실패를 MockMvc 수준에서 직접 검증하지 않는다.

P0는 데이터 손실 가능성, P1은 출시 전에 해결할 구조·정합성 문제, P2는 안정성과 회귀 방지 강화를 의미한다.

05 보안과 개인정보

현재 적용된 보호 장치와 보완 지점

잘 적용된 항목

- 비밀번호는 BCrypt PasswordEncoder로 해시되어 MEMBER.PASSWORD_HASH에 저장된다.
- Spring Security의 CSRF 보호를 끄지 않았으며 상태 변경은 POST 요청으로 구성했다.
- 마이페이지·배송지 등은 인증이 필요하고, 배송지 조회·수정 시 회원 ID를 함께 조건으로 사용한다.
- Google OIDC에서 email_verified=true를 확인한 후 계정을 연결한다.
- 인증 코드는 해시 저장되며 5분 만료, 최대 5회 시도, 1회 사용 규칙이 있다.

보완 권장

항목	현재	권장
DB 비밀번호	소스 기본값	환경변수 + 운영 비밀 저장소
메일 인증 로그	개발 log 모드에서 코드 출력	운영 프로필 차단 및 민감값 마스킹
세션	Spring 기본 세션	운영 HTTPS, Secure/HttpOnly/SameSite 정책 명시
탈퇴	상태를 WITHDRAWN으로 변경	개인정보 보유 근거·파기 시점과 익명화 정책 정의
OAuth 연결	같은 검증 이메일이면 자동 연결	정책 문서화 및 연결/해제 UI 검토

주의

개인정보 처리방침 화면이 존재하는 것과 실제 운영 절차가 준수되는 것은 별개다. 담당자 연락처, 보관 기간, 파기 작업, 위탁 업체는 배포 환경의 실제 값으로 확정해야 한다.

06 데이터 모델 리뷰

회원 중심 테이블과 무결성

테이블	역할	핵심 관계·제약
MEMBER	로컬 및 소셜 회원의 기준 계정	login_id, email unique / role, status
SOCIAL_ACCOUNT	외부 제공자 계정 연결	N:1 MEMBER / provider + provider_user_id unique
ADDRESS	회원 배송지	N:1 MEMBER / is_default Y·N
EMAIL_VERIFICATION	아이디 찾기·비밀번호 재설정 코드	email + purpose 기준 최신 요청 조회

무결성 평가

- 로그인 아이디와 이메일에 DB unique 제약이 있어 서비스 검사를 우회해도 기본 중복 방지가 가능하다.
- 소셜 제공자 사용자 ID 조합에 unique 제약이 있어 같은 Google 계정의 중복 연결을 막는다.
- 기본 배송지 1개 규칙은 서비스 로직으로 유지된다. 동시 요청이 많아지면 DB 차원의 보강이 필요하다.
- 회원 탈퇴는 물리 삭제가 아니라 상태 전환이므로 주문 연계가 추가될 때 참조 보존에 유리하다.

권장 변경

MEMBER에 SOCIAL_CREDENTIALS_CONFIGURED 또는 ACCOUNT_SETUP_STATUS를 추가하고, 이메일에는 애플리케이션 정규화 규칙을 강제한다. 스키마 변경 이력은 Flyway 같은 도구로 버전 관리하는 것이 좋다.

예시 상태 모델

PENDING_SOCIAL_SETUP → ACTIVE → WITHDRAWN

07 코드 품질

가독성, 중복, 예외 처리와 유지보수성

좋은 점

- DTO의 Bean Validation과 서비스의 업무 규칙 검증을 함께 사용한다.
- 최근 정리로 일반·소셜 가입의 보안 세션 생성이 signIn 메서드 하나로 통합됐다.
- 배송지 기본값 지정은 Address.makeDefault로 의도가 드러나며 전체 필드 재복사가 제거됐다.
- ObjectProvider와 조건부 OAuth 설정으로 Google 환경변수가 없을 때도 애플리케이션이 기동된다.

개선 제안

주제	제안
문자열 검증	비밀번호 정규식과 이메일 정규화 규칙을 공통 정책 클래스로 모아 DTO·서비스 중복을 줄인다.
예외	IllegalArgumentException 대신 DuplicateMember, InvalidCredential 등 의미 있는 예외를 사용하고 공통 처리기를 둔다.
Controller 형식	한 줄 try/catch와 여러 문장을 분리해 디버깅과 리뷰 가독성을 높인다.
시간	LocalDateTime.now() 직접 호출 대신 Clock을 주입하면 만료 테스트가 안정적이다.
조회 효율	첫 배송지 확인과 기본 배송지 초기화에 exists/bulk update 쿼리를 도입하면 전체 목록 로딩을 줄일 수 있다.

원칙

현재 규모에서는 추상화를 많이 추가하는 것보다 이메일 정규화, 상태 명시화, 예외 의미 개선처럼 오류 가능성을 직접 낮추는 리팩터링이 우선이다.

08 테스트 현황

실행 결과와 빠져 있는 회귀 시나리오

실행 결과

2026-07-29 기준 Maven 전체 테스트 9개 통과 / 실패 0 / 오류 0 / 건너뛴 0

현재 검증되는 내용

- Spring 애플리케이션 컨텍스트 기동
- 회원가입, 프로필 수정, 비밀번호 변경, 회원 탈퇴
- 아이디·이메일 중복 거절
- 기본 배송지 1개 유지
- 회원 화면과 개인정보 처리방침 렌더링
- 회원가입 직후 자동 로그인
- 이메일 인증 코드의 목적 구분과 1회 사용
- Google 신규 회원 생성·재사용 및 기존 이메일 계정 연결

추가해야 할 테스트

우선	시나리오	기대 결과
1	Google 신규 인증 성공	아이디·비밀번호 설정 화면으로 리다이렉트
2	Google 설정 완료 후 재로그인	설정 화면 없이 메인 이동
3	Google 설정 중 중복 아이디	저장되지 않고 오류 표시
4	이메일 대소문자 변형 가입	동일 이메일로 판단해 중복 거절
5	비밀번호 재설정 중 DB 실패	인증 코드 소비와 비밀번호 변경이 함께 롤백
6	타 회원 배송지 ID 접근	조회·수정·삭제 모두 차단

09 권장 개선 로드맵

작은 변경부터 운영 준비까지

단계	예상	작업	완료 기준
P0	0.5일	환경별 application 설정 분리	개발만 create-drop, 운영은 validate/migration
P1	0.5일	이메일 normalize 공통화	가입·Google·복구·중복검사가 동일 규칙 사용
P1	1일	소셜 설정 완료 상태 컬럼	loginId 접두어 판정 제거 및 기존 데이터 이행
P1	0.5일	DB 접속정보 환경변수화	소스에 실제 계정·비밀번호 없음
P2	1일	복구 유스케이스 트랜잭션 통합	코드 소비와 비밀번호 변경 원자성 보장
P2	1일	OAuth·권한 테스트 추가	최초/재로그인/중복/우회 접근 회귀 테스트
P3	1일	도메인 예외와 공통 오류 처리	화면별 중복 try/catch 감소

다음 기능 구현 전 체크리스트

- create-drop 설정이 의도된 개발 환경에서만 활성화되어 있는가?
- 회원 이메일은 모든 진입점에서 동일하게 정규화되는가?
- Google 최초 가입과 기존 계정 연결을 각각 테스트했는가?
- 탈퇴 회원, 인증 만료, 중복 요청 같은 실패 흐름이 화면에 안전하게 표시되는가?
- 운영 개인정보 처리방침의 담당자·보관기간·위탁사가 실제 값인가?

최종 의견

기능 골격은 잘 잡혀 있다. P0·P1 네 항목을 처리하면 팀 개발과 데이터 보존이 필요한 다음 단계로 넘어갈 수 있는 안정적인 기준선이 된다.

10 검토 근거

확인한 주요 파일과 범위

분류	파일
보안	common/config/SecurityConfig.java, GoogleOAuthConfig.java, PasswordConfig.java
회원	MemberController.java, MemberService.java, Member.java, JoinForm.java, ProfileForm.java, PasswordForm.java
소셜	CompickOidcUserService.java, SocialAccountService.java, CompickOidcUser.java, SocialAccount.java
복구	RecoveryController.java, EmailVerificationService.java, VerificationMailService.java
배송지	AddressController.java, AddressService.java, Address.java, AddressRepository.java
화면	templates/member/*, templates/privacy-policy.html, fragments/header.html, static/css/*
설정	src/main/resources/application.properties, pom.xml
테스트	CompickApplicationTests.java, MemberServiceIntegrationTests.java

검토 방식

정적 코드 확인, 설정 검토, 주요 사용자 흐름 추적, Maven 전체 테스트 실행 결과를 종합했다. 외부 침투 테스트, 실제 SMTP 발송, 실제 Google 콘솔 설정, Oracle 운영 부하 측정은 포함하지 않았다.

문서 버전

v1.0 / 2026-07-29 / 현재 워크스페이스 기준

COMPICK 회원 서비스 코드 리뷰 종료